

Vergabeakte

BSIG- und NIS2-Analyse für die SOC-Vergabe

Vorhaben: SOC Managed Service und ISB-Beratung

BSIG- und NIS2-Analyse für die SOC-Vergabe

Vergabeverfahren: LH-SN-Cyber-SOC-NSV-2026 Rechtsstand: 15.03.2026 Bearbeitung: Fachberatung
IT-Sicherheits- und Vergaberecht

1. Prüfauftrag

Zu klären ist, welche Pflichten aus dem seit 06.12.2025 geltenden BSI-Gesetz für die Nahverkehr Schwerin GmbH tatsächlich gelten und wie sie produktneutral, verhältnismäßig und prüfbar in Leistungsbeschreibung, Eignung, Zuschlag und Vertrag übersetzt werden. Die Verfahrensakte ordnet die Nahverkehr Schwerin GmbH nach den vorgelegten Betriebs- und Anlagendaten vorläufig als Betreiberin kritischer Anlagen ein. Vor der Freigabe sind diese Einordnung und die sektorspezifischen Schwellenwerte anhand der aktuellen gesetzlichen Anlagen und Verordnungen zu bestätigen.

2. Aktueller Normenrahmen

Thema	Normenanker	Vergabefolge
Einrichtungs- und Anlagenstatus	§§ 28 und 29 BSIG	Status nicht aus Branche oder Eigendarstellung ableiten; Größen-, Sektor- und Anlagenmerkmale belegen
Risikomanagement	§ 30 BSIG	Leistungsanforderungen aus konkretem Risiko ableiten, nicht pauschal jedes Zertifikat verlangen
Besondere Pflichten kritischer Anlagen	§ 31 BSIG	Systeme zur Angriffserkennung und Stand der Technik in überprüfbare Funktionsanforderungen übersetzen
Meldeprozess	§ 32 BSIG	Auftragnehmer-Zuarbeit und Eskalationszeiten so festlegen, dass der Betreiber seine gesetzlichen Stufen erfüllen kann
Registrierung	§ 33 BSIG	Verantwortlichkeit bleibt beim Unternehmen; der Dienstleister liefert Stammdaten und Änderungsinformationen
Nachweise kritischer Anlagen	§ 39 BSIG	Erst- oder erneuter Nachweis grundsätzlich innerhalb von drei Jahren, danach im Dreijahresrhythmus; konkreten Zyklus belegen
Kritische Komponenten	§ 41 BSIG	Kein pauschales Herkunftsverbot; Komponenten, Funktionen, Lieferkette und etwaige Untersagungsentscheidung risikobezogen prüfen

Die alten §§ 8a, 8b und 9b BSIG gehören zur bis Dezember 2025 geltenden Gesetzesfassung. Sie dürfen in einem Vorgang aus 2026 nur als historischer Bezug auf Alt-Audits verwendet werden, nicht als aktuelle Anspruchsgrundlage.

3. Betreiberpflicht und Auftragnehmerleistung trennen

Adressat der gesetzlichen Registrierung, Risikosteuerung, Meldung und Nachweisführung ist grundsätzlich die betroffene Einrichtung beziehungsweise der Betreiber. Ein SOC-Dienstleister unterstützt diese Pflichten vertraglich; er wird nicht allein durch den Auftrag zum gesetzlichen Betreiber. Die Vergabeakte muss daher für jede Anforderung ausweisen:

1. welche Betreiberpflicht abgesichert wird,
2. welche konkrete Leistung der Auftragnehmer schuldet,
3. welcher Nachweis bei Angebot, Leistungsbeginn und Betrieb verlangt wird und
4. welche Daten beim Betreiber verbleiben müssen.

4. Funktionale Leistungsanforderungen

Ein 24/7-SOC ist nicht allein aufgrund seiner Bezeichnung automatisch ein gesetzeskonformes System zur Angriffserkennung. Zu prüfen sind insbesondere Protokollquellen, Abdeckung betrieblicher Technik, Erkennungsregeln, Priorisierung, Eskalation, Nachvollziehbarkeit, Manipulationsschutz, Datenaufbewahrung, Testkonzept und kontinuierliche Verbesserung.

Für Vorfälle benötigt die Vergabestelle eine abgestufte Zuarbeit: sofortige interne Erstinformation, belastbare Fakten für die gesetzliche frühe Meldestufe, Aktualisierung für die Folgemeldung und Material für den Abschlussbericht. Die jeweils geltenden gesetzlichen Fristen und Ausnahmen werden vor Veröffentlichung gegen § 32 BSIG geprüft; Vertragsfristen müssen kürzer sein, damit Prüfung und Freigabe durch den Betreiber möglich bleiben.

5. Eignung, Zuschlag und Ausführung

- Eignung: nachgewiesene Fähigkeit zu vergleichbarer SOC-Leistung, qualifiziertes Personal, Informationssicherheitsmanagement und belastbare Lieferkette. ISO 27001 oder gleichwertige Nachweise zulassen (§ 122 Abs. 4 GWB, §§ 42 ff. VgV).
- Zuschlag: messbare Mehrwerte wie schnellere qualifizierte Reaktion, höhere Erkennungsabdeckung, bessere Wiederanlaufunterstützung und geprüfte Datenportabilität. Bewertungsstufen vorab veröffentlichen und mit Testfällen belegen (§ 127 GWB, § 58 VgV).
- Ausführung: Meldekooperation, Audit- und Exit-Rechte, Unterauftragnehmerwechsel, Schwachstellenprozess, Beweissicherung, Datenstandort und sichere Rückgabe.

Sektorerfahrung kann Qualität differenzieren. Ein Ausschluss allein wegen fehlender unmittelbarer ÖPNV-Referenz ist nur vertretbar, wenn die Anforderung auftragsbezogen, verhältnismäßig und eindeutig als Mindestanforderung bekannt gemacht wurde. In dieser Akte bezeichnet T-2 den Sektor lediglich als bevorzugt; die spätere Umdeutung zum Muss-Kriterium ist deshalb nicht tragfähig.

6. Komponenten- und Lieferkettenprüfung

§ 41 BSIG rechtfertigt kein automatisches Verbot aller Produkte aus bestimmten Drittstaaten und keine frei erfundene allgemeine Vorabgenehmigung. Die Vergabestelle erfasst stattdessen Hersteller, Produkt, kritische Funktion, Wartungszugriff, Updateweg, Abhängigkeiten und bestehende behördliche Entscheidungen. Nur daraus werden diskriminierungsfreie Mindestanforderungen oder Ausführungsbedingungen abgeleitet.

7. Quellenstatus vor Freigabe

Vor Veröffentlichung sind die aktuelle Fassung des BSIG, die Einrichtungs- und Anlagenkategorie, sektorspezifische Schwellenwerte, BSI-Hinweise und jede zitierte Entscheidung mit Stichtag und amtlicher Fundstelle zu prüfen. Unbestätigte Schwellenwerte, Produktlisten oder vermeintliche Zertifizierungspflichten werden als offene Prüfpunkte markiert und nicht als Muss-Anforderung ausgegeben.